Technical Report: Task-Secure Documentation

Project: Reusable Security Finding Documentation

Prepared for: RedKross Research Foundation internship task

Date: 17 October 2026

Author: Shourya

Intern ID: 2430

1. Executive summary

This project produces a reusable structure for recording security findings so that a second reviewer can understand the issue, reproduce it within an authorised environment, assess its impact, implement remediation, and verify the result. Deliverables include a finding template, a fully worked fictional finding using synthetic evidence, and repository documentation.

2. Objective

The objective is to standardise security finding records with enough technical detail for reproducibility and remediation while avoiding unsupported claims and unsafe handling of sensitive data. Required sections include title, scope, evidence, impact, severity rationale, remediation, references, and verification.

3. Background research

The template is informed by:

• OWASP Web Security Testing Guide, which provides structured guidance for web application security testing and reporting.

• OWASP Top 10:2025, used to contextualise broken access control.

• FIRST CVSS v4.0 specification, used as a reference for communicating severity when a score is actually calculated.

• MITRE CWE-639, used to describe the class of authorization weakness in the fictional example.

These references guide the format; they do not prove a vulnerability exists in any real system.

4. Methodology

1. Extract the required fields from the task brief.

2. Organise them into a lifecycle: metadata and scope, summary and reproduction, evidence, impact and severity, remediation, references, and verification.

3. Create a fictional object-level authorization finding using only reserved .test hostnames, invented account names, synthetic identifiers, and hand-authored request/response examples.

4. State expected and fictional observed behaviour separately.

5. Use a qualitative Medium severity rationale and explicitly avoid presenting an uncalculated CVSS score.

6. Include a remediation plan and a verification procedure, clearly marking retesting as not performed.

7. Structure repository files so the Markdown source remains editable and the PDFs are convenient for review.

5. Tools and technologies

• Markdown for editable source documentation and GitHub rendering.

• PDF generation for portable review copies.

• Public OWASP, FIRST, and MITRE references for background research.

• No live-target testing tools were used. The evidence in the example was hand-authored and is entirely synthetic.

6. Work performed and deliverables

• Designed a reusable finding template containing all required fields.

• Drafted a complete fictional finding covering broken object-level authorization.

• Included synthetic requests and responses, impact analysis, a qualitative severity rationale, remediation recommendations, references, and a retest plan.

• Prepared a README describing purpose, structure, safe usage, and submission placeholders.

7. Evaluation and results

A content review against the assignment requirements indicates that the template includes title, scope, evidence, impact, severity rationale, remediation, references, and verification. The worked example contains each section and distinguishes fictional observations from unperformed real-world testing. The README includes repository structure and a placeholder for the explanatory video URL.

This is a documentation completeness review, not a security test of a live application. No claim is made that a real vulnerability was discovered or fixed.

8. Limitations

• The finding is fictional and does not represent an actual assessment.

• Synthetic request/response pairs demonstrate documentation style only.

• Severity is qualitative; no CVSS score was calculated.

• No code change, remediation deployment, or retest was performed.

• Real severity depends on the environment, data sensitivity, exposure, exploit prerequisites, and compensating controls.

9. Recommendations

• Tailor scope and severity to each authorised engagement.

• Use a consistent severity rubric or calculate CVSS with a documented version, vector, and assumptions.

• Store evidence securely, redact secrets and personal data, and retain only what is necessary.

• Link each remediation to a measurable verification test.

• Require peer review for high-impact findings and record residual risk or accepted-risk decisions.

• Never test systems without explicit authorisation.

10. Conclusion

The project provides a reusable, evidence-oriented way to communicate security findings from discovery through verification. The fictional example demonstrates how to document reproducible steps and practical remediation without misrepresenting synthetic evidence as real testing.

11. References

1. OWASP, OWASP Top 10:2025 — A01 Broken Access Control. https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/

2. OWASP, Web Security Testing Guide. https://owasp.org/projects/web-security-testing-guide

3. FIRST, CVSS v4.0 Specification Document. https://www.first.org/cvss/v4.0/specification-document

4. MITRE, CWE-639: Authorization Bypass Through User-Controlled Key. https://cwe.mitre.org/data/definitions/639.html

Appendix A — Deliverable verification checklist

■ Reusable template includes all required sections.

■ Worked fictional finding uses synthetic evidence only.

■ Severity rationale explains assumptions and uncertainty.

■ Remediation and verification steps are included.

■ Technical report includes objective, research, methodology, tools, work, evaluation, limitations, recommendations, conclusion, and references.

■ Author name and Intern ID filled in.

■ Repository URL and explanatory video URL added to README.

■ Final repository links checked by the author before submission.